

SECURITY & GOVERNANCE

AI 시대 생성형 AI 활용과 내부정보 유출 통제 전략

“금지”가 아니라 “통제”로
생산성과 데이터 보호를 동시에

Waterwall™
Master of Internal Security **Systems**



업무 속 AI는 필연

"사용 금지"보다 통제 설계가 현실적인 이유

생성형 AI는 이미 현업에 깊숙이 침투했으며,
"사용 금지" 정책은 실효성이 낮고
통제 설계가 유일한 현실적 대안입니다.



전 세계적으로 조직의 생성형 AI 도입이
빠르게 확산되며 정기 사용 비율이 급증

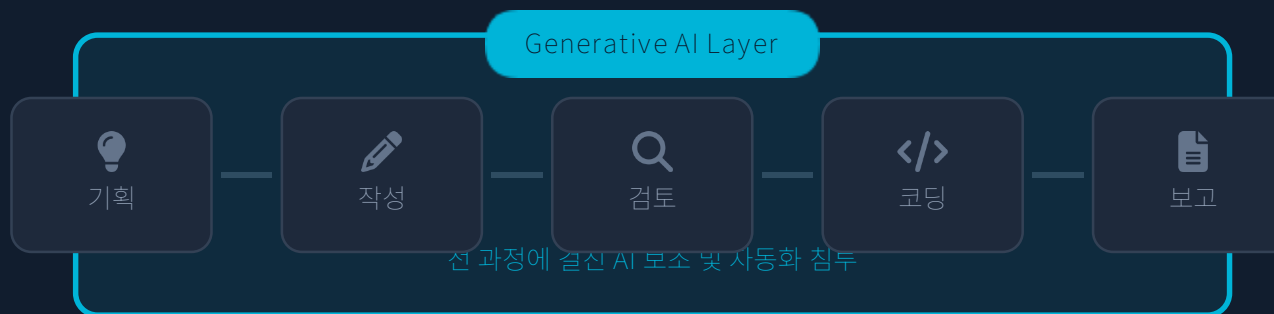
[1] McKinsey, *The state of AI in 2024* (2024-05)



업무자 단에서도 사용률이 빠르게 상승하여 필수적인 "
업무 도구"로 정착

[2] Cyberhaven, *4.2% of workers have pasted
company data...* (2023-02)

전통적 업무 프로세스 vs AI 통합 환경



! Insight

AI는 특정 단계의 도구가 아니라 업무 전반을 감싸는 인프라가 되었습니다. 단순 차단은 업무 프로세스 전체의 효율 저하를 초래할 수 있습니다.

생산성·품질 개선 근거

"그래서 더 못 막는다" - 현업의 자발적 사용 이유

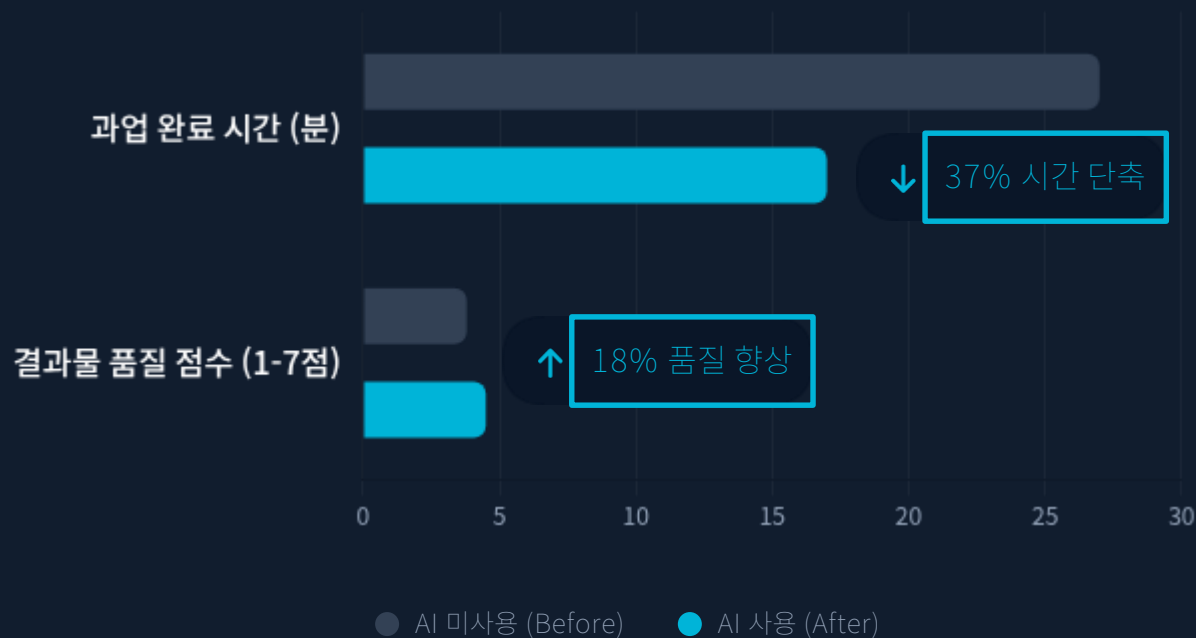
생성형 AI는 **시간 단축**과 **초안 품질 향상**이라는 명확한 효익이 있어, 현업이 이를 포기하기 어렵습니다.

 MIT 연구진의 실험 결과, 전문적인 글쓰기 및 업무 문서 생성 과업에서 AI 활용 그룹의 성과가 뚜렷하게 나타났습니다.

단순히 속도만 빨라지는 것이 아니라, 결과물의 품질(등급)까지 상승하는 이중 효과가 관측되었습니다.

[3] Noy & Zhang, "Experimental evidence on the productivity effects of generative AI", *Science* (2023)

생성형 AI 도입 전후 생산성 및 품질 변화





하지만 유출 위험도 증가했다

'의도치 않은 내부자 유출' 위험 급증

업무 편의 (+)



코드 생성 및 최적화
복잡한 로직 구현 시간 단축



문서 요약 및 번역
방대한 자료의 빠른 파악



초안 작성 지원
이메일, 보고서 구조 잡기

통제 부재 (-)



프롬프트로 기밀 반출
소스코드, 고객정보 붙여넣기



외부 학습 데이터화
입력된 데이터가 모델 학습에 재사용



유출 시도 급증
"사람의 습관 + 도구 확산" 결합 [4][5]

생성형 AI는 업무 효율을 높이는 도구이지만, 내부자가 기밀·개인정보를 '프롬프트로 반출'하기 쉬운 구조적 위험을 내포합니다.

[4] Cyberhaven, 4.2% of workers have pasted company data... (2023-02)

[5] Cyberhaven Labs, ChatGPT at Work Report (2023-05)



AI 시대 전·후 피해의 '산술적' 변화

유출 사고 비용 상승과 AI 확산의 상관관계

유출 사고의 평균 비용 자체가 상승했고(복합 IT·규제 비용), 'AI 확산'은 이를 더 자극하는 요인입니다.

COST INCREASE (2019-2024)

+ \$0.96M USD

글로벌 평균 데이터 유출 비용 약 24.5% 증가

2025년 전망:

수치는 일시 하락(\$4.44M)했으나, IBM은 'AI 거버넌스 격차' 및 'Shadow AI' 위험을 별도 이슈로 강조하며 잠재적 비용 증가를 경고했습니다.

글로벌 데이터 유출 평균 비용 추이 (단위: 백만 달러)



💡 AI 도입으로 인한 데이터 복잡성 증가는 사고 식별 및 복구 비용을 상승시키는 주요 원인입니다.



AI: "금지"가 아니라 "통제"

Shadow AI 방지와 안전한 활용을 위한 전략적 전환

사용 금지 (BAN)



공식 채널 차단

직원들의 니즈 무시



Shadow AI (우회) 증가

개인 기기/계정 사용으로 가시성 상실

보안 사고 위험 극대화

VS

사용 통제 (CONTROL)



공식 채널 제공 + 모니터링

안전한 가이드라인 제시



가시성(Visibility) 확보

누가/무엇을/어떻게 쓰는지 파악 가능

실질적 리스크 감소



"Shadow AI는 보안 사고와 비용을 키운다는 문제의식이 리포트와 업계에서 반복적으로 제기됩니다. 통제가 유일한 답입니다."

리스크 구조: '프롬프트 = 새로운 유출 채널'

기존 네트워크 경계를 우회하는 새로운 데이터 유출 경로





왜 통제가 어려운가: '기존 보안의 사각지대'

전통적 보안 경계와 AI 기반 신규 유출 경로의 차이

기존 반출 통제 (Legacy Security Solution)

메일, 메신저, 이동식 저장매체 중심

-  이메일 / 메신저
첨부파일 및 본문 키워드 필터링
-  USB / 외장하드
매체 제어 및 파일 복사 차단
-  출력물 보안
워터마크 및 출력 로그 감사

VS

신규 반출 경로 (Generative AI)

프롬프트, SaaS 입력창 중심 (빈틈 발생)

-  프롬프트 (Prompt)
소스코드/기밀 텍스트 '복사+붙여넣기'
-  파일 업로드 (Context)
문서/PDF를 통째로 분석 요청
-  이미지 업로드 (Multimodal)
도면/스크린샷 캡처 후 분석 요청

! "붙여넣기/업로드"가 주된 유출 시나리오로 부상 중



사례 1: 결함 소스코드 ChatGPT 입력

개발 편의를 위해 무심코 행한 '기밀 반출' 사고

CASE #1



디버깅 목적 입력

반도체 사업부 엔지니어가
프로그램 오류 해결을 위해
소스코드 원본을
ChatGPT 질의창에 붙여넣음

📅 2023. 04 🏢 제조/반도체



1. 인과관계 (Why)

내부 직원이 코드 결함을 빠르게 찾고 수정하기 위해, 회사 기밀인 소스코드를 외부 LLM 서비스에 직접 입력하여 해결책을 요청함.



2. 피해 및 리스크 (Risk)

입력된 소스코드가 외부(OpenAI) 서버로 전송됨. 정책·저장·학습 여부와 무관하게 "기밀 정보의 외부망 전송" 자체가 보안 사고 요건을 충족.



3. 당시 보안장치 및 대응 (Control)

초기엔 생성형 AI 사용 제한이 없거나 약했음(인식 부족). 사고 식별 후 '업로드 용량 제한' 및 '사용 금지' 등 강력한 물리적 차단 조치로 전환됨.



사례 2: 설비 코드 & 회의록 입력

소스코드 외에도 다양한 업무 부산물이 유출되는 패턴

CASE #2

불량 장비 식별 코드 최적화

설비/제조 관련 OT(운영기술) 분야



사고 인과관계 (Action)

직원이 대기오염 계측 및 수율 파악을 위한 설비 제어 프로그램 코드를 최적화하기 위해, 전체 코드를 ChatGPT에 입력함.

⚠ 핵심 리스크 (Risk)

제조/설비 관련 독자적 노하우 및 운영기술(OT) 정보가 외부로 반출되어 경쟁사에 노출될 잠재적 위험 발생.

CASE #3

사내 회의 녹음 → 회의록 생성

전략/기획 관련 비즈니스 분야



사고 인과관계 (Action)

직원이 스마트폰으로 녹음한 회의 내용을 문서 앱(Naver Clova 등)으로 변환 후, 요약 을 위해 ChatGPT에 전문을 입력함.

⚠ 핵심 리스크 (Risk)

회의에서 논의된 신제품 전략, 프로젝트 로드맵, 계약 조건 등 광범위한 기밀 정보가 한 번에 유출됨.



유출 대상은 단순한 소스코드에 국한되지 않습니다. 코드, 회의록, 이메일 초안 등 모든 '업무 부산물'이 입력 통제 대상이어야 합니다.



사례 3, 4 : 경영전략 문서 & 환자 정보 입력

직무를 막론하고 발생하는 '민감정보 붙여넣기' 패턴



기업 임원 (Executive)

전략기획 / 경영지원

- 업무 목적
이사회 발표용 프레젠테이션(PPT) 초안 생성
- 위험 행위 (Input)
회사의 '연간 전략 문서' 전체 텍스트를 ChatGPT에 붙여넣음
 연간 사업 계획서
- 유출 피해 (Leak)
M&A 계획, 투자 규모, 신제품 로드맵 등 핵심 경영 기밀이 외부 서버로 전송됨



의사 (Doctor)

의료 / 헬스케어

- 업무 목적
환자의 보험사 제출용 소견서 작성 효율화
- 위험 행위 (Input)
환자의 이름과 구체적인 증상/진단 내역을 그대로 입력
 환자 개인정보(PII)
- 유출 피해 (Leak)
가장 민감한 정보인 의료 기록 및 개인 식별 정보가 AI 학습 데이터로 노출 위험

! 공통 교훈: "어떤 보안 장치가 필요했나?"

사용자의 악의가 없더라도 편의성 때문에 사고는 발생합니다.
교육만으로는 한계가 있으며, 입력 순간(Prompt)의 실시간 탐지 및 차단 기술이 필수적입니다.





국내: 「인공지능 발전과 신뢰 기반 조성 등에 관한 기본법」 (AI 기본법)

국가 차원에서 AI 산업·기술 발전을 촉진하면서도, 안전·신뢰 확보를 위한 기본 틀



“최소 필요 규제”



고영향 AI에 대한 위험관리 의무



개인정보 보호 및 권리 침해 방지



투명성·책임성 확보 의무

시행 일

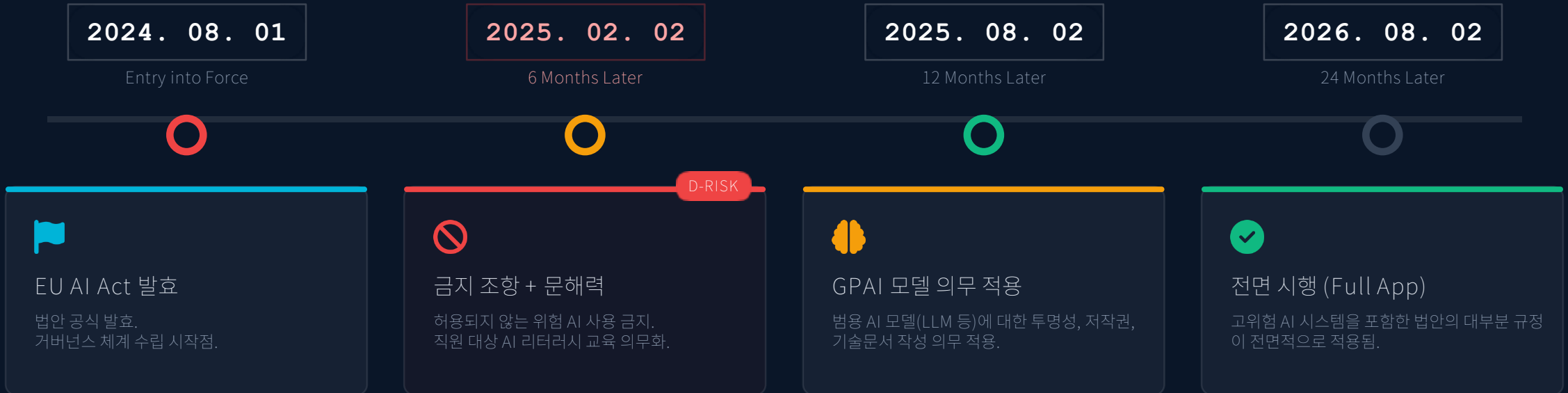
2026. 01. 22

"AI 기본법은 생성형 AI 사용을 막는 법이 아니라,
책임 있는 사용을 전제로 관리체계를 갖추도록 요구하는 법이다.
내부자에 의한 정보 유출 문제는 "사용 금지"가 아니라
거버넌스 + 기술적 통제 + 보안솔루션 도입의 문제



EU AI Act: 단계별 시행

"Stop the Clock" 없음 — 금지 행위 및 범용 모델(GPAI) 통제 준비 시급





거버넌스 공통 방향성: 글로벌 표준 프레임워크

규제의 언어는 달라도 기업에 요구하는 핵심 가치는 동일함

Risk Management

Accountability

Transparency

Control

Auditability



NIST AI RMF 1.0 AI 위험관리 프레임워크(AI RMF) 1.0

미국 국립표준기술연구소 (2023)

- ✓ 조직이 AI 위험을 체계적으로 관리하도록 4단계 프로세스(Map, Measure, Manage, Govern) 제시
- ✓ 자율적이지만 사실상의 글로벌 표준(De facto Standard) 역할

Map

Measure

Manage

Govern



ISO/IEC 42001

국제표준화기구 (2023)

- ✓ 세계 최초의 AI 경영시스템(AIMS) 국제 표준 인증 규격
- ✓ PDCA(Plan-Do-Check-Act) 사이클 기반의 지속적 개선 및 심사 가능성 확보

AIMS

PDCA

Certification



OECD AI 원칙

경제협력개발기구 (2019/2024)

- ✓ 국제 사회가 합의한 "신뢰할 수 있는 AI(Trustworthy AI)"의 공통 가치
- ✓ 핵심 원칙: 인간 중심 가치, 투명성/공정성, 안전성 및 보안, 책임성, 포용적 성장 및 지속 가능성
- ✓ 설명 가능성 등 윤리적 가이드라인의 모태

Trustworthy

Human-centric

Ethics



전략 원칙: " 정책(거버넌스) + 반출 모니터링"

사후 대응(Detection) 중심에서 사전 차단/예방(Prevention) 중심으로 이동

Visibility First

가시성(Visibility) 없이는 통제도 불가능합니다. "누가, 언제, 어디로" 데이터를 보내는지 먼저 파악해야 합니다.

Unified Control

정책(Policy)과 기술(Technology)은 분리될 수 없습니다. 거버넌스 정책이 기술 시스템에 즉시 반영되는 구조여야 합니다.

Enablement

무조건적인 차단은 우회(Shadow AI)를 부릅니다. "안전한 길"을 열어주고 그 안에서 통제해야 합니다.



1. AI 사용 정책 (Governance)

DEFINE

허용 서비스(Whitelist), 업무 범위, 금지 데이터(PII·기밀·고객정보·소스코드)의 명확한 정의 및 가이드라인 수립.

Data Classification

Usage Policy

Allowed Apps



2. 접근 경로 통제 (Access Control)

ROUTE

프록시(Proxy) 또는 보안 게이트웨이(SWG/CASB)를 통해 사내의 모든 AI 트래픽을 '관리 가능한 단일 경로'로 중앙 집중화.

Secure Gateway

Traffic Decryption

User Auth



3. AI DLP 모니터링 검사 (Inspection)

BLOCK

입력되는 프롬프트, 업로드 파일, 생성된 응답을 실시간 분석하여 민감정보 포함 시 즉시 차단 및 로그/증적 확보.

Real-time DLP

PII Detection

Audit Logs

DLP의 AI 통제 기능으로 무분별한 AI 사용의 7가지 필수 통제

무엇을(What), 어떻게(How), 왜(Why) 통제해야 하는가?



1. 모니터링 (가시성)

01

누가, 언제, 어떤 AI 서비스에 접속했는지 전수 기록하여 'Shadow AI' 사용 현황을 먼저 시각화합니다.



2. 질의/응답 로그 수집

02

프롬프트와 응답 내용을 로그로 보존하여, 사고 발생 시 '어떤 데이터가 유출되었는지' 증거를 확보합니다.



4. 부서/시간대별 통제

04

개발팀은 코드 생성 도구 허용, 인사팀은 PII 입력 금지 등 직무와 역할(Role)에 기반하여 정책을 차등 적용합니다.



3. 개인정보 패턴 탐지

03

주민번호, 계좌, 이메일, 전화번호 등 정규식 패턴과 사내 정의 키워드를 실시간 탐지해 입력 단계에서 차단합니다.



5. 파일 업로드 차단

05

기밀 등급 문서, 개인정보가 포함된 엑셀/PDF 파일의 AI 서비스 업로드를 원천적으로 차단합니다.



6. 이미지 업로드 차단

06

설계도면, UI 스크린샷 등 이미지 내 정보 유출을 막기 위해 이미지 첨부 기능을 비활성화하고 로그를 남깁니다.



7. 프롬프트 길이 제한

07

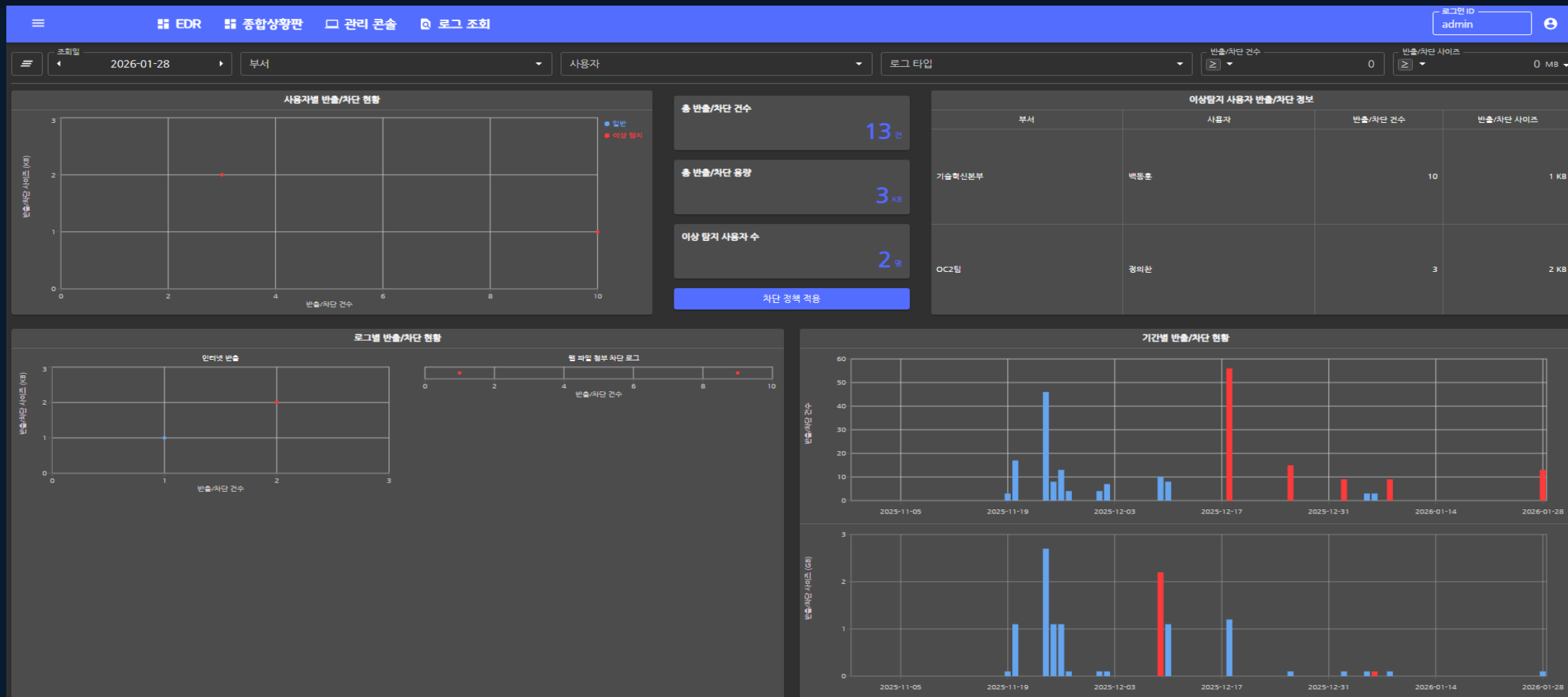
프롬프트 글자 수를 제한하여 문서 전체를 '복사+붙여넣기'하여 대량으로 반출하는 행위를 구조적으로 방지합니다.

Why This Matters? 위 통제 항목들은 "직원이 업무 편의를 위해 민감정보를 붙여넣는 실제 사고 사례(삼성전자, 의료계 등)"에 직접 대응하는 필수 통제 세트입니다.



보안 솔루션의 진화: 무분별한 반출 모니터링 감사

입력되는 프롬프트, 업로드 파일, 생성된 응답을 실시간 분석하여 민감정보 포함 시 즉시 차단 및 로그/증적 확보.





보안 솔루션의 진화: 반출 통제 중심 + 정책 통합

단순 차단을 넘어 문맥(Context)을 이해하고 규제를 준수하는 체계로 진화



입력 단계(Input) 중심 제어

기존 네트워크/메일 통제에서
프롬프트/파일 입력 창(Input Box) 통제



행위 + 문맥(Context) 기반 결합

단순 키워드 매칭을 넘어
업무/부서/프로젝트 문맥과
이상 행동을 결합한 정밀 탐지.



규제 대응 통합 체인(Chain)

정책(Policy) → 탐지 → 차단 → 감사가
하나의 파이프라인으로 연결되어
컴플라이언스 증적을 자동 확보.

“

“차단만 하면 우회합니다. 대신 허용된 길을 만들고,
그 길 안에서만 빠르게 쓰게 해주면서 민감정보만 정확히 막는 방식이 지속 가능합니다.”

KEY MESSAGE FOR STAKEHOLDERS



Conclusion & Next Steps

생산성과 데이터 보호를 동시에 달성하기 위한 마지막 제언

"AI 흐름은 막을 수 없습니다. 대신 '불법적 반출'은 막을 수 있습니다."

무조건적인 금지는 Shadow AI라는 더 큰 위험을 부릅니다. 이제 '안전한 통제'가 유일한 해답입니다.

규제 준수는 기본값

2026년 대한민국 AI기본법 시행 및 EU AI Act 단계별 적용으로, '통제 체계 구축'과 '증적 확보'는 선택이 아닌 필수 생존 조건이 되었습니다.

생산성과 보안의 양립

보안은 AI 도입의 걸림돌이 아닙니다.
안전한 가드레일(Guardrail)이 있을 때, 임직원은 더 과감하게 AI를 업무에 활용할 수 있습니다.

FIRST PRIORITY ACTION

지금 당장 시작해야 할 첫 번째 조치: 가시성 확보를 위한 보안 조치 시행 및 반출 추적 통제!

우리 조직의 AI 사용 현황(Shadow AI)을 파악하는 모니터링부터 시작하십시오.